

# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 1 頁，共 9 頁

單選題 50 題 (佔 100%)

|   |                                                                                                                                                                                                                                                    |
|---|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C | <p>1. 某公司人員開啟社交工程攻擊信件，導致其公司電腦遭駭客植入惡意程式，駭客藉此將電腦機密檔案傳輸出外，還將檔案刪除。請問上述情境中，下列哪些資安的特性被破壞？</p> <p>(A) 只有機密性遭受破壞</p> <p>(B) 只有完整性遭受破壞</p> <p>(C) 可用性以及機密性均遭受破壞</p> <p>(D) 完整性以及可用性均遭受破壞</p>                                                                |
| D | <p>2. 關於資訊安全管理系統 (Information Security Management System, ISMS)，下列敘述何者較「不」正確？</p> <p>(A) 導入資訊安全管理系統可以保護組織資訊資產的安全</p> <p>(B) 要建立良好的資訊安全管理系統，需要制度面與技術面互相配合</p> <p>(C) 最高管理階層的參與及支持是成功建立資訊安全管理系統的重點之一</p> <p>(D) 在建立組織資訊安全管理系統的活動中，識別弱點會優先於識別資訊資產</p> |
| D | <p>3. 下列何種標準是針對雲端服務個人隱私資料的保護？</p> <p>(A) ISO/IEC 27001</p> <p>(B) ISO/IEC 27002</p> <p>(C) ISO/IEC 27017</p> <p>(D) ISO/IEC 27018</p>                                                                                                              |
| B | <p>4. 下列何者屬於資料完整性受影響？</p> <p>(A) 機密資料外洩</p> <p>(B) 檔案遭毀損而無法存取</p> <p>(C) 系統無法正常提供服務</p> <p>(D) 資料以明文方式傳輸</p>                                                                                                                                       |
| B | <p>5. 請問資通安全責任等級分級辦法，將適用機關的責任等級，共分幾級？</p> <p>(A) 4</p> <p>(B) 5</p> <p>(C) 6</p> <p>(D) 7</p>                                                                                                                                                      |
| A | <p>6. 下列何者是目前國際上唯一與資訊安全相關，且可作為國際認證論壇 (International Accreditation Forum, IAF) 認可的管理系統驗證？</p> <p>(A) ISO/IEC 27001</p> <p>(B) ISO/IEC 27002</p> <p>(C) ISO/IEC 27005</p> <p>(D) ISO/IEC 27006</p>                                                   |

# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 2 頁，共 9 頁

|   |                                                                                                                                                                                                          |
|---|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A | 7. 下列何者「不」屬於我國智慧財產權保護的相關法令？<br>(A) 個人資料保護法<br>(B) 營業秘密法<br>(C) 商標法<br>(D) 專利法                                                                                                                            |
| A | 8. 為保障信用卡持卡人的資料安全，制定統一的資料安全標準，提供資料安全的技術與作業要求之基準，此行為屬於下列何者？<br>(A) PCI DSS<br>(B) HIPAA<br>(C) Sarbanes-Oxley Act<br>(D) Basel II                                                                         |
| C | 9. 關於 General Data Protection Regulation (GDPR) 的規範要求，下列敘述何者較「不」正確？<br>(A) GDPR 為歐盟一般資料保護法規<br>(B) 任何使用與歐盟公民相關資訊的公司都應評估遵循<br>(C) 雲端處理者與控制者目前不納入 GDPR 強制實施範圍<br>(D) 要求持有個人可識別資訊的組織，需實施適切的安全控制措施，以防止個人資料遺失 |
| D | 10. 關於資通安全管理法所定義的防護基準中，要求密碼「不」得明文存放，是規範在下列何種控制構面中？<br>(A) 系統與通訊保護<br>(B) 系統與服務獲得<br>(C) 存取控制<br>(D) 識別與鑑別                                                                                                |
| C | 11. 下列何者「不」是依個資法第 8 條之規定，向當事人蒐集個人資料時，應明確告知當事人的事項？<br>(A) 個人資料類別<br>(B) 個人資料利用之期間、地區、對象及方式<br>(C) 個人資料數量<br>(D) 當事人得自由選擇提供個人資料時，不提供將對其權益之影響                                                               |
| C | 12. 關於智慧財產權 (Intellectual Property Rights)，下列敘述何者較「不」正確？<br>(A) 專利權、著作權、營業秘密皆屬於智慧財產權<br>(B) 可將合法授權的軟體光碟複製一份作為備用<br>(C) 推薦網路上的音樂歌名給朋友會違反智慧財產權<br>(D) 原版軟體版權皆屬於智慧財產權所保護的範圍                                 |
| A | 13. 所有權 (Property) 是資訊倫理常探討的四大議題之一，關於所有權，                                                                                                                                                                |

# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 3 頁，共 9 頁

|   |                                                                                                                                                                                         |
|---|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | <p>下列敘述何者較為正確？</p> <p>(A) 誰擁有資訊</p> <p>(B) 誰負責資訊的真實性與正確性</p> <p>(C) 在何種狀況保護措施下，可向他人揭露那些個人資料</p> <p>(D) 在何種條件下，個人與組織有權利來獲取所需資料</p>                                                       |
| D | <p>14. 下列何者「不」屬於資訊資產分類中的服務資產？</p> <p>(A) 電力供應</p> <p>(B) 網路供應</p> <p>(C) 空調供應</p> <p>(D) 公用程式</p>                                                                                       |
| D | <p>15. 關於資訊資產控管原則，下列敘述何者較「不」正確？</p> <p>(A) 資產分類分級是資訊安全控管的重要程序之一</p> <p>(B) 資產分類通常是為了之後進行風險管控作業所需</p> <p>(C) 根據資產等級的不同，配合資產類別給予適當的控管措施</p> <p>(D) 各組織針對所擁有之資訊資產不同，絕不會因定義不同而有不同資訊資產分類</p> |
| D | <p>16. 關於資訊資產的保管權責，下列敘述何者較「不」正確？</p> <p>(A) 權責單位 (Owner) 並不一定需具備財產權</p> <p>(B) 保管單位 (Keeper) 負有善盡保管之責任義務</p> <p>(C) 使用單位 (User) 負有合理使用的義務</p> <p>(D) 使用單位 (User) 負責該資產的生命週期管理與維護</p>    |
| D | <p>17. 為了確保資訊依其對組織之重要性，受到適切等級的保護，下列何種控制措施與此目標較「不」具直接相關？</p> <p>(A) 資訊之分級</p> <p>(B) 資訊之標示</p> <p>(C) 資訊之處理</p> <p>(D) 資產擁有權</p>                                                         |
| A | <p>18. 資訊資產價值需考量資訊資產的機密性、完整性及可用性，下列何種資訊資產的機密性價值更高？</p> <p>(A) 人事資料</p> <p>(B) 公司官網</p> <p>(C) 線上學習系統</p> <p>(D) 公務機關出國報告</p>                                                            |
| D | <p>19. 關於資產清冊，下列敘述何者較「不」正確？</p> <p>(A) 在進行資產管理時，應優先建立資產清冊</p> <p>(B) 將可移除式媒體載於資產清冊上，可減少資料遺失的機會</p> <p>(C) 資產清冊需要識別與資訊及資訊處理設施有關的資產，並應予文</p>                                              |

# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 4 頁，共 9 頁

|   |                                                                                                                                                                                          |
|---|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | <p>件化</p> <p>(D) 組織所有的資產，都應明列在資訊資產清冊上，也都需要標示購置時的成本和費用</p>                                                                                                                                |
| D | <p>20. 公司機房重地購買地震險或火險，此行為屬於下列何種風險處理方式？</p> <p>(A) 風險接受 (Acceptance)</p> <p>(B) 風險規避 (Avoidance)</p> <p>(C) 風險降低 (Reduction)</p> <p>(D) 風險移轉 (Transfer)</p>                               |
| C | <p>21. 在資安風險管理過程中，關於風險識別 (Risk Identification) 應包括的工作項目，下列何者較「不」正確？</p> <p>(A) 識別威脅 (Threat)</p> <p>(B) 識別脆弱點 (Vulnerability)</p> <p>(C) 識別風險等級 (Risk Level)</p> <p>(D) 識別資產 (Asset)</p> |
| A | <p>22. 為避免機房在一樓會有淹水的風險，而將機房搬到較高樓層，請問這是何種風險處理行為？</p> <p>(A) 風險規避 (Avoidance)</p> <p>(B) 風險移轉 (Transfer)</p> <p>(C) 風險降低 (Reduction)</p> <p>(D) 風險接受 (Acceptance)</p>                      |
| D | <p>23. 關於風險評鑑管理程序，下列敘述何者較「不」正確？</p> <p>(A) 建立全景係界定風險評鑑範圍</p> <p>(B) 詳細風險評鑑包括風險識別、風險分析與風險評估</p> <p>(C) 風險處理若符合風險處理準則，則進入風險接受階段</p> <p>(D) 風險評鑑若不符合風險評鑑準則，則進入風險溝通階段</p>                    |
| D | <p>24. 關於風險降低 (Reduction)，下列敘述何者「不」正確？</p> <p>(A) 其方式包括日常稽核遵守控制程度</p> <p>(B) 其方式包括處理偶發事故的計畫</p> <p>(C) 其方式包括找出相較於現有的控制方法，新的控制方法所可能帶來的相對利益</p> <p>(D) 其方法包括契約的簽訂、保險和機關的結構，如合夥經營和共同投資</p>  |
| D | <p>25. 關於風險分析，下列敘述何者較「不」正確？</p> <p>(A) 風險分析的目的是找出風險發生的可能性</p> <p>(B) 風險分析用於評估風險等級</p> <p>(C) 風險分析可分析事件發生的影響性</p>                                                                         |

# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 5 頁，共 9 頁

|   |                                                                                                                                                                                                                                                                                                                          |
|---|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | (D) 風險分析會影響風險準則的訂定                                                                                                                                                                                                                                                                                                       |
| C | <p>26. 存取控制 (Access Control) 決定使用者與作業系統之間的溝通，防止系統資源或資料被未經授權地存取。請問下列何者「不」是存取控制在組織中主要區分的三種操作模式？</p> <p>(A) 強制存取控制 (Mandatory Access Control, MAC)</p> <p>(B) 任意存取控制 (Discretionary Access Control, DAC)</p> <p>(C) 屬性存取控制 (Attribute-based Access Control, ABAC)</p> <p>(D) 角色基準存取控制 (Role-based Access Control, RBAC)</p> |
| C | <p>27. 關於存取控制 (Access Control)，下列敘述何者較「不」正確？</p> <p>(A) 需依據不同角色，賦予不同的資料存取權限</p> <p>(B) 需依據資料的機密層級不同，去設立存取權限</p> <p>(C) 將所有存取角色皆設定為共同權限，以方便程式開發操作使用</p> <p>(D) 記錄所有的存取事件，以便未來追蹤使用</p>                                                                                                                                     |
| B | <p>28. 為鑑別使用者身份，常採用多因素驗證，下列何者「不」屬於多因素驗證的設計原理？</p> <p>(A) Something you know</p> <p>(B) Something you want</p> <p>(C) Something you have</p> <p>(D) Something you are</p>                                                                                                                                                 |
| C | <p>29. 關於特權帳號 (Privileged Account) 的管理行為，下列敘述何者較「不」適當？</p> <p>(A) 定期修改密碼</p> <p>(B) 設定複雜性密碼，且首次登入時須變更預設密碼</p> <p>(C) 使用系統預設帳號作為管理者執行實際管理工作</p> <p>(D) 限縮系統預設管理者帳號之權限</p>                                                                                                                                                 |
| D | <p>30. 若運用「生物特徵」來做身分認證時，儀器的最佳靈敏度必須調整在誤殺 (False Reject) 與誤放 (False Accept) 兩條曲線的交叉點，此交叉點被稱為下列何種錯誤率？</p> <p>(A) 位元錯誤率 (Bit Error Rate)</p> <p>(B) 封包錯誤率 (Packet Error Rate)</p> <p>(C) 測試錯誤率 (Test Error Rate)</p> <p>(D) 交點錯誤率 (Crossover Error Rate)</p>                                                                 |
| C | <p>31. 關於自然人憑證，下列敘述何者「不」正確？</p> <p>(A) 自然人憑證是基於公開金鑰基礎建設 (Public Key Infrastructure, PKI) 架構下之應用</p> <p>(B) 自然人憑證在網路上使用時，其代表申請人之身分識別上具有法律效力</p>                                                                                                                                                                           |



# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 6 頁，共 9 頁

|   |                                                                                                                                                                                                          |
|---|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | (C) 自然人憑證申請一次永久有效，無需換發<br>(D) 自然人憑證於網路上的相關應用具有不可否認性                                                                                                                                                      |
| C | 32. 遠端用戶撥入驗證服務 (Remote Authentication Dial In User Service, RADIUS) 是 AAA 三種服務的網路傳輸協議，關於此 AAA，下列何者「不」正確？<br>(A) Authentication<br>(B) Authorization<br>(C) Access<br>(D) Accounting                      |
| C | 33. 關於存取控制 (Access Control) 需求的申請及審核，下列敘述何者「不」正確？<br>(A) 需要申請及審核機制<br>(B) 應定期檢視申請內容與當前需求是否一致<br>(C) 申請人主管審核通過即可由申請人逕行設定<br>(D) 組織應制定政策規範，使管理人員有所依循                                                       |
| A | 34. 關於最小權限原則 (Principle of Least Privilege, PoLP)，下列敘述何者「不」正確？<br>(A) 最小權限原則指的是使用者的權限，不包含系統程序的權限<br>(B) 最小權限原則的核心是僅提供執行任務所需的最小權限<br>(C) 最小權限原則可以避免被濫用或是盜用時造成的破壞<br>(D) 最小權限原則為現行資安權限設定常用的準則之一            |
| B | 35. 關於驗證 (Authentication) 與授權 (Authorization)，下列敘述何者正確？<br>(A) 輸入帳號密碼是屬於 Authorization<br>(B) CEO 可調閱資料是屬於 Authorization<br>(C) 使用者輸入 MFA Token 是屬於 Authorization<br>(D) 警察將嫌犯扣留 72 小時是屬於 Authentication |
| B | 36. 關於身分識別與存取管理 (Identity and Access Management, IAM)，下列敘述何者較「不」恰當？<br>(A) 使用者應妥善保管 IC 卡，不可任意外借他人使用<br>(B) 帳號與權限清查無須留下相關軌跡<br>(C) 任何使用者均需輸入帳號及密碼，以進行使用者身分鑑別<br>(D) 專案或工作結束時，應刪除與系統營運或維護無關之帳號             |
| C | 37. 下列何者「不」是對稱式加密 (Symmetric Encryption)？<br>(A) 資料加密標準 (Data Encryption Standard, DES)<br>(B) 三重資料加密演算法 (Triple DES, 3DES)<br>(C) 橢圓曲線密碼學 (Elliptic Curve Cryptography, ECC)                            |

# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 7 頁，共 9 頁

|   |                                                                                                                                                                                                                                                                                                                 |
|---|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | (D) RC6 加密演算法 (Rivest Cipher 6, RC6)                                                                                                                                                                                                                                                                            |
| B | <p>38. 關於公鑰 (Public Key) 與私鑰 (Private Key) 加解密，下列敘述何者「不」正確？</p> <p>(A) 公私鑰加解密演算法使用「公鑰加密」與「私鑰解密」</p> <p>(B) 數位簽章的時候，傳送端使用自己的公鑰製作簽章，接收端使用傳送端的私鑰驗證簽章</p> <p>(C) 公鑰加密系統是多人都可以拿公鑰加密，但是只有一個人可以拿私鑰解密</p> <p>(D) 數位簽章系統是只有一個人可以拿私鑰製作簽章，但是多人都可以拿公鑰驗證簽章</p>                                                               |
| B | <p>39. 下列何種方式「不」能加強替換式密碼破解的難度？</p> <p>(A) 使用諧音替換</p> <p>(B) 改用凱薩密碼</p> <p>(C) 隨意添加字元</p> <p>(D) 使用非字典用語</p>                                                                                                                                                                                                     |
| A | <p>40. 關於網站加密連線方式，下列敘述何者「不」正確？</p> <p>(A) SSL/TLS 僅採用對稱式加密方式完成</p> <p>(B) SSL/TLS 加密過程中主要是透過 SSL/TLS 交握協定 (Handshake Protocol) 以及 SSL 紀錄協定 (Record Protocol) 兩階段完成運作</p> <p>(C) 網路上傳輸的資訊，若未經過任何加密，則任何人取得封包片段後即可觀察封包傳輸內容，這也是網站傳輸必須使用加密連線的原因</p> <p>(D) SSL/TLS 等網站傳輸加密協定運作於 TCP/IP Model 為 Application Layer</p> |
| B | <p>41. 為分析資安事件的根本原因，會利用有價值的網路、資料、電腦系統，故意設置脆弱性的伺服主機，來吸引駭客攻擊，以瞭解駭客入侵技術及行為模式，此行為屬於下列何者？</p> <p>(A) 多層次防禦 (Layered Defense)</p> <p>(B) 蜜罐 (HoneyPot)</p> <p>(C) 滲透測試 (Penetration Test)</p> <p>(D) 黑箱測試 (Black-Box Testing)</p>                                                                                     |
| C | <p>42. 關於資安事件、事故之處理，下列敘述何者「不」正確？</p> <p>(A) 資安事件是指網路流量大增、連線速度緩慢，且由防火牆日誌中發現有異常之連線紀錄，但尚未導致資訊系統主要功能降低或喪失</p> <p>(B) 若發現駭客已侵入網路及主機，應判斷遭受駭客入侵影響之範圍，迅速截斷相關網路設備之連結，避免駭客入侵範圍擴大</p>                                                                                                                                      |

# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 8 頁，共 9 頁

|   |                                                                                                                                                                                                                              |
|---|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | <p>(C) 若發現失去電力供應時，儘速通報機電人員聯繫電力公司瞭解狀況，以進行後續處理，而此類事件不屬於資訊安全事件，不需要記錄及彙整處理過程</p> <p>(D) 資安事件或事故應變處理時，應嚴格管制人員，禁止非必要人員參與</p>                                                                                                       |
| D | <p>43. 公司收到主管機關要求，必須每年進行網路資安健檢，下列何種處理較「不」符合？</p> <p>(A) 遠端網路弱點掃描 (Network Vulnerability Assessment)</p> <p>(B) 遠端滲透測試 (Penetration Testing)</p> <p>(C) 到場網頁應用程式弱點掃描 (Web Vulnerability Assessment)</p> <p>(D) 到場網路安全備援服務</p> |
| A | <p>44. 處理資安事件時，蒐集硬碟資料證據，進行位元對位元的拷貝，目的在取得法院能接受的證據，此行為屬於下列何者？</p> <p>(A) 電腦鑑識 (Computer Forensics)</p> <p>(B) 滲透測試 (Penetration Test)</p> <p>(C) 風險分析 (Risk Analysis)</p> <p>(D) 網路弱點掃描 (Network Vulnerability Assessment)</p> |
| D | <p>45. 依據「行政院國家資通安全會報通報及應變作業流程」，判定事故影響等級時，應評估資安事故造成之機密性、完整性以及可用性衝擊，下列何者「不」是 4 級事件？</p> <p>(A) 國家機密資料遭洩漏</p> <p>(B) 關鍵資訊基礎設施系統或資料遭嚴重竄改</p> <p>(C) 關鍵資訊基礎設施運作遭影響或系統停頓，無法於可容忍中斷時間內回復正常運作</p> <p>(D) 機關業務系統或資料短暫停頓無法使用</p>       |
| B | <p>46. 關於營運持續管理活動，下列何者為正確的順序？(a)擬定營運持續計畫 (BCP)、(b)調整營運持續策略、(c)營運衝擊分析 (BIA)、(d)定期演練</p> <p>(A) a b c d</p> <p>(B) c b a d</p> <p>(C) b a c d</p> <p>(D) a c b d</p>                                                           |
| D | <p>47. 關於營運持續管理 (Business Continuity Management, BCM)，下列敘述何者較「不」正確？</p> <p>(A) 確保組織的利益最大化</p> <p>(B) 確保人員的成本最小化</p> <p>(C) 確保組織在發生重大災害時，業務持續不中斷</p>                                                                          |



# 110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 11 月 20 日

第 9 頁，共 9 頁

|   |                                                                                                                                                                                                                                                   |
|---|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | (D) 確保組織在購併其他產業時，可以迅速的完成                                                                                                                                                                                                                          |
| D | 48. 若您希望能估計營運可承受之最長中斷時間（Maximum Tolerable Period of Disruption），最有可能從下列何者取得？<br>(A) 平衡計分卡（Balanced Score Card）<br>(B) 風險評鑑（Risk Assessment）<br>(C) 恢復點目標（Recovery Point Objective）<br>(D) 營運衝擊分析（Business Impact Analysis）                        |
| A | 49. 在進行營運持續規劃時，若評估發現公司資料遺失之最大可接受程度為 10 分鐘內，應考慮下列何者？<br>(A) 恢復點目標（Recovery Point Objective, RPO）<br>(B) 恢復時間目標（Recovery Time Objective, RTO）<br>(C) 工作恢復時間（Work Recovery Time, WRT）<br>(D) 最大可容忍中斷時間（Maximum Tolerable Period of Disruption, MTPD） |
| C | 50. 下列何者「不」屬於復原程序之項目？<br>(A) 於備援設備中安裝作業系統與應用程式<br>(B) 於復原系統重新載入備份資料<br>(C) 復原系統上線後重新評估災害發生風險<br>(D) 測試復原系統之功能是否正常                                                                                                                                 |